AWS SECURITY SERVICES

AWS WAF & Shield

Web Application Firewall — Complete Technical Reference

Tuesday, April 07, 2026

Table of Contents

1. Introduction & Overview
2. Web Application Attack Landscape
    - Common Web Application Threats
    - Attack Volume Statistics
5. Defense in Depth Strategy
6. AWS WAF Architecture
    - Core Components & Hierarchy
    - WAF Capacity Units (WCU)
    - Supported AWS Resources
    - Regional vs. Global Web ACLs
11. WAF Rule Types
    - Managed Rule Groups
    - Custom Rules & Match Statements
    - Rate-Based Rules
15. WAF Logging and Monitoring
    - Logging Destinations
    - CloudWatch Metrics
18. Production-Level Knowledge
    - Testing & Validation
    - Cost Optimization
21. Tips & Best Practices
22. Pitfalls & Remedies
23. Summary & Key Takeaways
24. Hands-On Lab Exercise

1. Introduction & Overview

Web applications face constant attack — automated bots scanning for vulnerabilities, credential stuffing attempts cycling through stolen passwords, SQL injection probing databases, DDoS floods overwhelming infrastructure, and zero-day exploits targeting unpatched software. Traditional security approaches — network firewalls, IP blocking, rate limiting at the load balancer — cannot protect modern web applications from sophisticated, distributed, application-layer attacks.

AWS WAF (Web Application Firewall) and **AWS Shield** provide intelligent, scalable protection directly integrated with CloudFront, Application Load Balancer, and API Gateway, blocking attacks at the edge before they reach your infrastructure.

$4M+	$100K/hr	96%	400+
Average data breach cost	DDoS revenue loss potential	DDoS attacks mitigated by Shield Standard	CloudFront edge locations

WAF in Multi-Cloud — AWS | Azure | GCP

In today's cloud-first world, a well-architected WAF sits in front of your workloads and defends against modern threats while ensuring OWASP Top 10 compliance.

Cloud	CDN / Edge	WAF	DDoS Protection
AWS	CloudFront	AWS WAF	AWS Shield
Azure	Front Door	Azure WAF	Azure DDoS Protection
GCP	Cloud CDN	Cloud Armor	Cloud Armor (built-in)

TAKEAWAY

A strong WAF strategy is not just about blocking traffic — it's about intelligent filtering, visibility, and zero trust enforcement across multi-cloud environments.

2. Web Application Attack Landscape

Common Web Application Threats

Threat	Description & Example	Impact	AWS Prevention
SQL Injection	Malicious SQL in input fields `' OR '1'='1' --`	Database compromise, data theft	WAF SQL injection rule set
XSS	Inject malicious JavaScript `<script>steal_cookies()</script>`	Session hijacking, data theft	WAF XSS rule set
Directory Traversal	Access unauthorized files `../../etc/passwd`	File system exposure	WAF path traversal rules
Command Injection	Execute system commands `; cat /etc/passwd`	Server compromise	WAF OS command injection rules
Bot Attacks	Scraping, credential stuffing, inventory hoarding, account abuse	Content theft, account takeover	WAF Bot Control
DDoS	Layer 3/4 volumetric or Layer 7 application exhaustion	Service unavailability	Shield Standard + Advanced
Zero-Day	Exploit unknown vulnerabilities (Log4Shell, Heartbleed)	System compromise	WAF managed rule groups (rapid updates)

Attack Volume Statistics (2024)

43%
Increase in web application attacks

67%
Attacks targeting application layer

94%
Organizations experiencing DDoS

3.47 Tbps
Largest recorded DDoS (AWS mitigated)

3. Defense in Depth Strategy

Layer 1 **Network (VPC)**

Security groups, Network ACLs, Private subnets — Network-level access control

Layer 2 **Edge (CloudFront + Shield)**

Shield Standard always-on DDoS, geographic distribution, SSL/TLS termination — Network/transport layer DDoS protection

Layer 3 **Web Application Firewall (WAF)**

Request inspection, rate limiting, bot detection, managed rule groups — Application-layer attack protection

Layer 4 **Application (Code)**

Input validation, parameterized queries, output encoding — Defense against coding vulnerabilities

Layer 5 **Data (Encryption)**

Encryption at rest (KMS), encryption in transit (TLS) — Data protection if perimeter breached

Layer 6 **Monitoring (Security Hub)**

GuardDuty threat detection, CloudTrail audit logs, WAF logging — Incident detection and response

Complete Traffic Stack: Internet → Shield → CloudFront → WAF → ALB → Application → Database

Each layer reduces attack surface. Multiple layers compensate if one fails.

4. AWS WAF Architecture

Core Components — Web ACL Hierarchy

```
Web ACL (Access Control List)
├── Default Action (Allow or Block)
├── Rules (ordered by priority)
│   ├── Managed Rule Groups (AWS/Marketplace)
│   ├── Custom Rules
│   └── Rate-based Rules
├── Capacity Units (WCU limit: 1,500)
└── Associated Resources (CloudFront, ALB, API Gateway)
```

Rule Evaluation Order

1. Rules evaluated in priority order (0 = highest priority)
2. First matching rule action is applied
3. If no rules match → default action applied
4. Terminates on first match (no further evaluation)

WAF Capacity Units (WCU)

Each rule consumes WCUs based on complexity. The Web ACL limit is **1,500 WCUs**.

Rule Type	WCU Cost
Simple rule	1 WCU
IP set rule	1 WCU
Rate limit rule	2 WCUs
Complex rule	50+ WCUs
AWS Core Rule Set	700 WCUs
SQL Injection rule set	200 WCUs
Known Bad Inputs	200 WCUs
Bot Control	50 WCUs
Anonymous IP List	50 WCUs
IP Reputation List	25 WCUs

Supported AWS Resources

Resource	Deployment	Use Case
Amazon CloudFront	Global (deploy to us-east-1); 400+ edge locations	Global websites, APIs, content delivery — lowest latency
Application Load Balancer (ALB)	Regional Web ACL per region	Web applications, microservices
API Gateway (REST)	Regional Web ACL per API stage	RESTful APIs, serverless backends
AWS AppSync (GraphQL)	Regional Web ACL per API	GraphQL applications

Regional vs. Global Deployment Pattern

```
Global Application:
CloudFront (Global WAF) ──> ALB us-east-1 (Regional WAF)
                        ──> ALB eu-west-1 (Regional WAF)

Benefits:
• Edge protection at CloudFront
• Additional protection at ALB
• Defense in depth
```

5. WAF Rule Types

1. Managed Rule Groups

AWS Managed Rule Groups

Rule Group	Protection	Cost	WCU
Core Rule Set	OWASP Top 10: SQLi, XSS, LFI, RFI	$1/mo + $0.60/M req	700
Known Bad Inputs	Known malicious patterns, CVE signatures, exploit patterns	$1/mo + $0.60/M req	200
SQL Database	SQL injection, database-specific patterns	$1/mo + $0.60/M req	200
Linux OS	Linux exploits, command injection, file inclusion	$1/mo + $0.60/M req	200
Bot Control	Automated bot detection; verified bots (Googlebot) allowed	$10/mo + $1/M req	50
Anonymous IP List	Block Tor exit nodes, VPNs, proxies, anonymizers	$1/mo + $0.60/M req	50
IP Reputation List	AWS threat intelligence, known malicious IPs, botnets	Free	25

> **MINIMUM PRODUCTION SETUP**
>
> **Core Rule Set** (OWASP) + **Known Bad Inputs** (CVE) + **IP Reputation List** (threat intelligence)
>
> Total WCU: 925 | Total Cost: $2/month + $1.20/million requests

2. Custom Rules — Match Statement Types

Geographic Match

```
{
  "GeoMatchStatement": {
    "CountryCodes": ["CN", "RU", "KP"]
  }
}
```

IP Set Match

```
{
  "IPSetReferenceStatement": {
    "ARN": "arn:aws:wafv2:...:ipset/blocked-ips"
  }
}
```

Size Constraint

```
{
  "SizeConstraintStatement": {
    "FieldToMatch": {"Body": {}},
    "ComparisonOperator": "GT",
    "Size": 8192,
    "TextTransformations": [{"Priority": 0, "Type": "NONE"}]
  }
}
```

SQL Injection Match (Custom)

```
{
  "SqliMatchStatement": {
    "FieldToMatch": {"UriPath": {}},
    "TextTransformations": [{"Priority": 0, "Type": "URL_DECODE"}]
  }
}
```

String Match (Exact)

```
{
  "ByteMatchStatement": {
    "SearchString": "admin",
    "FieldToMatch": {"UriPath": {}},
    "TextTransformations": [{"Priority": 0, "Type": "LOWERCASE"}],
    "PositionalConstraint": "CONTAINS"
  }
}
```

Text Transformations

Transformation	Purpose
`NONE`	No transformation
`LOWERCASE`	Convert to lowercase
`URL_DECODE`	Decode URL encoding
`HTML_ENTITY_DECODE`	Decode HTML entities
`BASE64_DECODE`	Decode base64
`CMD_LINE`	Normalize command line
`COMPRESS_WHITE_SPACE`	Remove extra spaces

3. Rate-Based Rules

Basic Rate Limit (per IP)

```
{
  "RateBasedStatement": {
    "Limit": 2000,   // Requests per 5 minutes
    "AggregateKeyType": "IP"
  }
}
```

Scoped Rate Limit (Login Endpoint)

```
{
  "RateBasedStatement": {
    "Limit": 100,
    "AggregateKeyType": "IP",
    "ScopeDownStatement": {
      "ByteMatchStatement": {
        "SearchString": "/api/login",
        "FieldToMatch": {"UriPath": {}},
        "TextTransformations": [{"Priority": 0, "Type": "NONE"}],
        "PositionalConstraint": "EXACTLY"
      }
    }
  }
}
```

Custom Key Rate Limit (Per API Key / Session)

```
{
  "RateBasedStatement": {
    "Limit": 50,
    "AggregateKeyType": "CUSTOM_KEYS",
    "CustomKeys": [
      {"Header": {"Name": "X-API-Key"}},
      {"Cookie": {"Name": "session_id"}}
    ]
  }
}
```

Tiered Rate Limiting Strategy

Layer	Scope	Limit	Purpose
Layer 1 — Aggressive	Global (edge)	10,000 req / 5 min	Protects infrastructure
Layer 2 — Moderate	API endpoints	1,000 req / 5 min	Balances usability and security
Layer 3 — Strict	Login / auth	10 req / 5 min	Prevents credential stuffing
Layer 4 — Per-User	Authenticated session	100 req / 5 min	Prevents account abuse

6. WAF Logging and Monitoring

Logging Destinations

Destination	Use Case	Key Benefit
Amazon S3	Long-term storage, compliance/audit, query with Athena	Cost-effective; unlimited retention
CloudWatch Logs	Real-time monitoring, Insights queries, alarms, dashboards	Integrated alerting; higher cost for large volume
Kinesis Data Firehose	Real-time streaming to Elasticsearch, Splunk, custom analytics	SIEM integration; real-time transformation

WAF Log Format (JSON)

```
{
  "timestamp": 1642176000000,
  "formatVersion": 1,
  "webaclId": "arn:aws:wafv2:...",
  "terminatingRuleId": "RateLimitRule",
  "terminatingRuleType": "RATE_BASED",
  "action": "BLOCK",
  "responseCodeSent": 403,
  "httpRequest": {
    "clientIp": "203.0.113.1",
    "country": "US",
    "uri": "/api/login",
    "args": "username=admin",
    "httpVersion": "HTTP/1.1",
    "httpMethod": "POST",
    "requestId": "uuid-1234-5678"
  }
}
```

Key Fields for Analysis

Field	Values	Use
`action`	ALLOW, BLOCK, COUNT	Request disposition
`terminatingRuleId`	Rule name	Which rule matched
`httpRequest.clientIp`	IP address	Source IP
`httpRequest.uri`	Path string	Target endpoint
`httpRequest.country`	ISO country code	Geographic origin
`responseCodeSent`	HTTP status (403, etc.)	Response sent to client

CloudWatch WAF Metrics

Metric	Description	Use
AllowedRequests	Count of allowed requests	Baseline normal traffic
BlockedRequests	Count of blocked requests	Attack detection
CountedRequests	Count mode (testing rules)	Rule validation before blocking
SampledRequests	Sample of last 3 hours (max 1,000)	Debugging specific rules

Shield Advanced Metrics

Metric	Description	Use
DDoSDetected	Binary: 0 (none) / 1 (attack)	Trigger alarms
DDoSAttackBitsPerSecond	Attack volume (bits/second)	Attack volume analysis
DDoSAttackPacketsPerSecond	Attack volume (packets/second)	Attack analysis
DDoSAttackRequestsPerSecond	Application-layer attack volume	Layer 7 attack detection

Logging Best Practices

- Log to S3 for cost-effective long-term storage
- Use CloudWatch Logs for real-time alerts
- Sample logs (reduce volume and cost — 1% sufficient for analysis)

- Set lifecycle policies (delete after 90 days)
- Encrypt logs (SSE-S3 or SSE-KMS)
- Redact authorization headers, cookies, API keys for compliance

7. Production-Level Knowledge

WAF Testing and Validation

False Positive Management Process

Phase	Action	Duration
1 — COUNT Mode	Deploy rule in COUNT mode; monitor all matched requests; identify false positives	1–2 weeks
2 — Analyze	Review sampled requests; adjust rule or add exceptions; re-test in COUNT mode	Ongoing
3 — BLOCK 10%	Use CloudFront weighted distribution; 10% sees BLOCK, 90% sees COUNT	Observe
4 — BLOCK 50%	Increase if no issues; continue monitoring	Observe
5 — BLOCK 100%	Full rollout; ongoing monitoring for new false positives	Permanent

Cost Optimization

WAF Pricing Summary

Component	Price
Web ACL	$5/month per Web ACL
Rules	$1/month per rule
Request Processing	$0.60 per million requests
Core Rule Set (managed)	$1/month + $0.60/M requests
Bot Control (managed)	$10/month + $1/M requests
Shield Advanced (base)	$3,000/month (WAF included at no charge)

Example Monthly Costs

Scale	Requests/Month	Breakdown	Total
Small Website	10M	ACL $5 + Rules $5 + Core $1 + Requests $6	~$17/mo
Medium Website	100M	ACL $5 + Rules $8 + Managed $3 + Requests $60	~$76/mo
Large Website	1B	ACL $5 + Rules $15 + Managed $15 + Bot $10 + Requests $1,100	~$1,145/mo

Optimization Strategies

Strategy	How	Savings
Consolidate Rules	Use 2 complex rules instead of 10 simple rules	Up to $8/month per set
Use Managed Rule Groups	AWS-maintained; often cheaper than custom equivalent; no custom WCU consumption	Significant at scale
Sample Logging	Log 1% of requests instead of 100%	99% of logging costs
CloudFront Caching	90% cache hit: 1B req → 100M WAF-billed requests	~$990/month at large scale
Rate Limiting	Block excessive requests early; reduces billable requests; protects against cost attacks	Variable

8. Tips & Best Practices

WAF Configuration Tips

Tip 1 — Start with Managed Rule Groups

Use AWS Managed Rules for OWASP Top 10 protection — continuously updated, no maintenance required.

Tip 2 — Deploy Rules in COUNT Mode First

Test all rules in COUNT mode for 1–2 weeks before blocking — identifies false positives safely.

Tip 3 — Implement Layered Rate Limiting

Use multiple rate limits: global (10K/5min), API (1K/5min), login (10/5min) — protects different attack vectors.

Tip 4 — Enable Request Sampling

Sample requests provide debugging context — essential for investigating blocked legitimate traffic.

Tip 5 — Use Regex Pattern Sets for Efficiency

Group similar patterns into regex sets — reduces WCU consumption, easier management.

Shield and DDoS Protection Tips

Tip 6 — Enable Shield Advanced for Critical Applications

Revenue loss greater than $125/hour justifies $3K/month — includes DRT support and cost protection.

Tip 7 — Configure Health-Based Detection

Associate Route 53 health checks with Shield — enables automatic attack detection based on application health.

Tip 8 — Implement Application-Level Throttling

WAF + application throttling provides defense in depth — WAF blocks attacks, app throttles prevent resource exhaustion.

Tip 9 — Use CloudFront with Shield Standard

CloudFront + Shield Standard protects 96% of DDoS attacks free — excellent baseline protection.

Tip 10 — Document Incident Response Procedures

Maintain runbooks for common attacks — enables rapid response when attacks occur.

Monitoring and Logging Tips

Tip 11 — Query WAF Logs with Athena

Store logs in S3, query with Athena — cost-effective analysis of millions of requests.

Tip 12 — Set CloudWatch Alarms on Blocked Requests

Alert when blocked requests exceed normal baseline — early attack detection.

Tip 13 — Create Custom Dashboards

Visualize attack patterns, top blocked IPs, geographic distribution — enables rapid situational awareness.

Tip 14 — Integrate with SIEM

Send WAF logs to Splunk/QRadar via Kinesis Firehose — centralized security monitoring.

Tip 15 — Redact Sensitive Data from Logs

Redact authorization headers, cookies, API keys — compliance and privacy protection.

9. Pitfalls & Remedies

Pitfall 1 — False Positives Blocking Legitimate Traffic

Problem: WAF rules block legitimate users, causing service disruption and customer complaints.

Why It Happens

- Overly aggressive managed rules without tuning
- Rate limits too strict for actual usage patterns
- Geographic blocking affects legitimate international users
- SQL injection rules triggered by legitimate data (e.g. apostrophes in product names)
- Bot detection blocking automated tools (monitoring, CI/CD)

Real Example

E-commerce site enables Core Rule Set. Product search for *"O'Reilly Books"* triggers SQL injection rule (single quote flagged as SQLi). 500 legitimate users blocked on Day 1; $50,000 in lost sales.

Remedy

- Always test in COUNT Mode first (1–2 weeks)
- Analyze sampled requests to identify false positives
- Implement exception rules for known-good patterns
- Gradual rollout: COUNT → BLOCK 10% → BLOCK 50% → BLOCK 100%
- Monitor customer feedback channels; maintain easy rollback procedures

Pitfall 2 — Insufficient Rate Limiting Configuration

Problem: Rate limits too high allow attacks through; too low block legitimate traffic.

Why It Happens

- Default limits don't match application usage
- Single global rate limit for all endpoints
- No consideration for authenticated vs. anonymous traffic
- Peak traffic patterns not analyzed before setting limits

Real Example

Configuration: 2,000 req/5min per IP. Attack: 10,000 bot IPs each send 1,999 requests — total 19.99M requests/5min overwhelm the application while staying under the per-IP limit.

Remedy

- Analyze baseline traffic before setting limits
- Implement tiered limits (global, API, auth endpoints)
- Test limits under peak traffic conditions
- Monitor rate limit alarms; adjust based on application growth

Pitfall 3 — Inadequate Logging and Monitoring

Problem: Security incidents undetected due to missing logs or alerts.

Why It Happens

- Logging not enabled at deployment
- Logs not integrated with monitoring systems
- No CloudWatch alarms configured
- Cost concerns prevent full logging

Real Example

Credential stuffing attack ran undetected for **72 hours**. 50 million login attempts; 150 accounts compromised. No alerting on failed login spike. Detected only via customer complaints.

Remedy

- Enable logging on day one (S3 + CloudWatch + Kinesis)
- Configure CloudWatch alarms on blocked requests threshold
- Automate log analysis; integrate with SIEM
- Review security dashboards weekly
- Document investigation procedures

10. Summary & Key Takeaways

AWS WAF and Shield provide comprehensive protection against web application attacks and DDoS threats at massive scale. WAF enables granular request filtering using customizable rules, managed rule groups, rate limiting, bot detection, and geographic blocking to protect against OWASP Top 10 vulnerabilities and application-layer attacks. Shield delivers always-on DDoS protection — Shield Standard mitigates 96% of attacks automatically at no cost, while Shield Advanced adds application-layer protection, 24/7 DDoS Response Team support, and real-time attack visibility.

- **Deploy Managed Rule Groups First:** Core Rule Set + Known Bad Inputs + SQL Injection covers most attacks for $2/month
- **Test Rules in COUNT Mode:** Deploy new rules in COUNT mode for 1–2 weeks before blocking; analyze sampled requests before enabling BLOCK
- **Implement Tiered Rate Limiting:** Global (5K/5min) + API (1K/5min) + Login (10/5min); protects endpoints appropriately
- **Enable Shield Standard Everywhere:** Always-on DDoS protection free with CloudFront, Route 53, ALB, Global Accelerator
- **Consider Shield Advanced for Critical Apps:** $3K/month justified when revenue loss exceeds $125/hour; includes DRT support and cost protection
- **Enable Comprehensive Logging:** S3 (storage) + CloudWatch (alarms) + Kinesis (SIEM); redact sensitive headers
- **Integrate with CloudFront:** CloudFront + WAF + Shield provides edge protection; blocks attacks before reaching origin

Service Integration Chain: WAF and Shield integrate seamlessly with CloudFront distributions, Application Load Balancers, and API Gateway REST APIs, while Shield Standard protects the entire AWS edge network automatically — together with Security Hub, GuardDuty, and KMS, providing defense-in-depth from network edge to data storage.

11. Hands-On Lab Exercise

Objective: Build complete web application protection with WAF, Shield, monitoring, and automated response.

Scenario: Protect an e-commerce website from SQL injection, credential stuffing, and DDoS attacks.

Prerequisites

- AWS account with admin access
- Application Load Balancer serving web application
- CloudFront distribution (optional)

Lab Steps

1. **Create WAF Web ACL (45 min)**
   - Create regional Web ACL
   - Add AWS Managed Core Rule Set
   - Add SQL Injection rule group
   - Add Known Bad Inputs rule group
   - Test rules in COUNT mode
   - Associate with ALB

2. **Configure Rate Limiting (30 min)**
   - Add global rate limit (5,000 req/5min)
   - Add API rate limit (1,000 req/5min)
   - Add login rate limit (10 req/5min)
   - Test with load testing tool; verify blocking at thresholds

3. **Geographic and IP Blocking (20 min)**
   - Create IP set for known malicious IPs
   - Add IP blocking rule
   - Add geographic blocking (high-risk countries)
   - Test access from blocked regions

4 Enable Logging and Monitoring (40 min)

- Enable WAF logging to S3
- Create CloudWatch log group
- Configure CloudWatch alarm: blocked requests > 1,000
- Create CloudWatch dashboard
- Test alarm triggering

5 Simulate Attacks (30 min)

- SQL injection attempt (verify blocking)
- Exceed rate limits (verify throttling)
- Analyze WAF logs and sampled requests
- Review CloudWatch metrics
- Test automated alert notifications

6 Enable Shield Advanced (Optional — $3K/month)

- Subscribe to Shield Advanced
- Add protected resources
- Configure health-based detection
- Review DDoS Response Team contact

Expected Outcomes

- Web ACL protecting against OWASP Top 10
- Rate limiting preventing credential stuffing
- Comprehensive logging for incident investigation
- CloudWatch alarms detecting attacks in real-time
- Complete protection for < $20/month (10M requests)